

TRƯỜNG ĐẠI HỌC FPT

Viện Đào tạo Sau Đại học

**Kiến trúc Nhận thức Hai tầng cho
Phát hiện và Phản hồi Mối đe dọa
Tự động sử dụng AI Tác tử**

Đề cương Luận văn Thạc sĩ

Học viên: Nguyễn Đức Bình

MSSV: MSE13183

Giảng viên hướng dẫn: Bùi Văn Hiệu

Hà Nội, 2026

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh (SOC) đang phải đối mặt với một “Nghịch lý Dữ liệu lớn” nghiêm trọng: khối lượng khổng lồ các sự kiện mạng phát sinh mỗi giây dẫn đến tình trạng quá tải cảnh báo, với phần lớn trong số đó là dương tính giả. Các hệ thống Phát hiện Xâm nhập (IDS) và Quản lý Sự kiện An ninh (SIEM) truyền thống thường phân tích luồng dữ liệu một cách đơn lẻ, qua đó làm suy giảm đáng kể khả năng nhận diện các chiến dịch tấn công có chủ đích tinh vi (APT). Gần đây, việc ứng dụng trực tiếp các Mô hình Ngôn ngữ Lớn (LLM) vào việc phân tích log đã được thử nghiệm; tuy nhiên, hướng đi này lại mở ra hai lỗ hổng rủi ro lớn: độ trễ suy luận quá cao không thể đáp ứng được tốc độ của luồng dữ liệu thời gian thực, và nguy cơ hệ thống LLM bị thao túng bởi các đòn tấn công Prompt Injection ẩn giấu ngay bên trong dữ liệu log độc hại.

Để giải quyết triệt để những thách thức này, nghiên cứu đề xuất một kiến trúc nhận thức (cognitive architecture) kết hợp giữa một Động cơ Quy tắc (Rule Engine) xác định và một Mô hình Ngôn ngữ Lớn. Thông qua phương pháp tiếp cận hai tầng, hệ thống được kỳ vọng sẽ sàng lọc lượng lớn nhiễu ở tốc độ cao (Tầng 1), đồng thời bảo lưu năng lực suy luận sâu — được vận hành bởi AI Tác tử dựa trên LangGraph cùng cơ chế Dual-RAG (tích hợp MITRE ATT&CK cho nhận diện mối đe dọa và NIST SP 800-61r2 cho hướng dẫn ứng phó sự cố) — để xử lý các mối đe dọa phức tạp và khó đoán (Tầng 2). Bên cạnh đó, một cơ chế Đóng gói Dữ liệu có Phân cách (Delimited Data Encapsulation) cũng được giới thiệu nhằm vô hiệu hóa các nỗ lực chèn mã độc vào prompt mà không làm mất đi thông tin payload quan trọng cần thiết cho việc điều tra sự cố.

Hệ thống đề xuất sẽ được triển khai và đánh giá trên hai bộ dữ liệu chuẩn: CSE-CIC-IDS2018 cho phát hiện xâm nhập mạng doanh nghiệp và DAPT2020 cho theo dõi tấn công APT đa giai đoạn. Các tiêu chí đánh giá sẽ được cấu trúc theo Khung Đánh giá 5 Chiều (5-Dimensional Evaluation Framework) toàn diện, bao quát Chỉ số Phân loại, Chỉ số Vận hành, Mức độ Kháng lỗi, Chất lượng Ngữ cảnh và Tính Giải thích.

Mục lục

Tóm tắt	1
1 Giới thiệu và Bối cảnh	4
1.1 Mô tả Vấn đề	4
1.2 Mục tiêu Nghiên cứu	4
1.3 Câu hỏi Nghiên cứu	5
1.4 Đối tượng và Phương pháp Nghiên cứu	5
1.5 Phạm vi Nghiên cứu	5
1.6 Cấu trúc Luận văn	6
2 Tổng quan Nghiên cứu	7
2.1 Các Phương pháp Nền tảng	7
2.2 Các Công trình Liên quan	7
2.2.1 Phân tích So sánh các Phương pháp Hiện có	8
3 Giải pháp Đề xuất và Phương pháp Nghiên cứu	9
3.1 Giải pháp Đề xuất: Kiến trúc Nhận thức Hai tầng	9
3.2 Công nghệ và Công cụ	11
3.2.1 Cấu hình Phần cứng	12
4 Kế hoạch Triển khai và Đánh giá	13
4.1 Các Giai đoạn Phát triển Chính	13
4.2 Kế hoạch Đánh giá	13
4.3 Kế hoạch Thực hiện	14
5 Kết quả Kỳ vọng và Đóng góp Khoa học	16
5.1 Kết quả Kỳ vọng và Thực nghiệm	16
5.2 Đóng góp Khoa học	16

6 Kết luận	18
Tài liệu tham khảo	19

1. Giới thiệu và Bối cảnh

1.1 Mô tả Vấn đề

Các Trung tâm Điều hành An ninh (SOC) hiện đại đang bị nhấn chìm bởi khối lượng sự kiện an ninh khổng lồ. Các báo cáo chuyên ngành gần đây chỉ ra rằng một phân tích viên SOC trung bình phải xử lý hàng nghìn cảnh báo mỗi ngày, trong đó gần một nửa bị xác định là dương tính giả [1]. Hiện tượng “quá tải cảnh báo” (alert fatigue) này trực tiếp dẫn đến việc các mối đe dọa nguy hiểm thực sự bị bỏ sót. Thêm vào đó, các hệ thống IDS/SIEM truyền thống thường phân tích từng nguồn dữ liệu (Web log, Firewall log) một cách rời rạc, làm giảm nghiêm trọng khả năng tương quan để phát hiện các chuỗi tấn công đa giai đoạn tinh vi.

Việc ứng dụng Mô hình Ngôn ngữ Lớn (LLM), đặc biệt là kiến trúc AI Tác tử (Agentic AI) và Retrieval-Augmented Generation (RAG), vào việc phân tích log tự động sinh ra những lỗ hổng chí mạng về cả vận hành lẫn bảo mật. Thứ nhất, độ trễ suy luận (reasoning latency) của hệ thống là quá cao đối với các môi trường luồng dữ liệu thời gian thực. Thứ hai, các kiến trúc Agentic AI mở rộng bề mặt tấn công (attack surface) vượt xa các LLM truyền thống. Các hệ thống tự trị này đặc biệt nhạy cảm với một phổ các véc-tơ tấn công tinh vi: các đòn *Indirect Prompt Injection* và *Jailbreaks* ẩn trong dữ liệu log [2], nơi kẻ tấn công chèn chỉ thị độc hại vào các trường động (ví dụ: User-Agent) nhằm thao túng logic của Agent. Hơn nữa, việc cấp quyền thực thi cho Agent tạo ra rủi ro *Thoát hộp cát* (*Sandbox Escape*) và *Thực thi mã từ xa* (*RCE*), trong khi việc hiển thị đầu ra của LLM trên bảng điều khiển mở ra lỗ hổng *Rò rỉ dữ liệu* (*Data Exfiltration*) thông qua render Markdown độc hại. Thêm vào đó, sự phụ thuộc vào cơ sở tri thức bên ngoài đặt hệ thống trước nguy cơ *Đầu độc tri thức* (*RAG Poisoning*), nơi kẻ xấu thay đổi tài liệu tham chiếu để bóp méo nhận thức ngữ cảnh của Agent. Điều này tạo ra một nghịch lý lớn: phân tích viên bắt buộc phải cấp cho Agent ngữ cảnh động và khả năng thực thi để điều tra các cuộc tấn công, nhưng việc này lại mở ra nguy cơ toàn bộ cơ sở hạ tầng SOC bị chiếm quyền điều khiển.

1.2 Mục tiêu Nghiên cứu

Nhận thấy những hạn chế trên, nghiên cứu này đặt mục tiêu phát triển một AI Security Agent tự trị dựa trên kiến trúc nhận thức hai tầng (cognitive two-tier architecture). Thay vì hoàn toàn phụ thuộc vào một LLM duy nhất để xử lý mọi log, luận văn đề xuất một kiến trúc hybrid lai: một động cơ quy tắc tốc độ cao kết hợp với một LLM Agent có khả năng suy luận sâu. Hướng tiếp cận này được kỳ vọng sẽ tối ưu hóa độ trễ suy luận bằng cách lọc nhiễu, giảm thiểu nguy cơ prompt injection qua cơ chế đóng gói có ranh giới, và nâng cao khả năng nhận

thức ngữ cảnh thông qua Bộ nhớ Rủi ro Dài hạn (Long-Term Threat Memory) và kiến trúc Dual-RAG. Một bảng điều khiển (Dashboard) kết hợp yếu tố Human-in-the-Loop (HITL) cũng sẽ được xây dựng để chứng minh tính thực tiễn của tự động hóa SOC.

1.3 Câu hỏi Nghiên cứu

Dựa trên các mục tiêu đã đề ra, luận văn tập trung giải quyết bốn câu hỏi nghiên cứu cốt lõi: 1. Việc áp dụng Kiến trúc Hai tầng (Rule-based + LLM Agent) kết hợp với Cơ sở Hành vi theo Phiên (Session-Aware Behavioral Baseline) có tối ưu hóa Độ trễ Suy luận so với phương pháp Một tầng (chỉ dùng LLM) hay không? 2. Liệu cơ chế Đóng gói Dữ liệu có Phân cách (Delimited Data Encapsulation) có thể ngăn chặn hiệu quả các đòn Prompt Injection mang tính cấu trúc (ví dụ: Delimiter Smuggling) mà không làm suy giảm độ chính xác phân loại của LLM? 3. Kiến trúc Dual-RAG (kết hợp khung chuẩn chiến thuật và kiểm soát phòng thủ) cải thiện Độ phù hợp Ngữ cảnh (Context Relevance) của quá trình phân tích rủi ro do LLM thực hiện như thế nào? 4. Một vòng lặp phản hồi (Feedback Loop) mang tính thích ứng với cơ chế Cách ly HITL (HITL Quarantine) có thể ngăn chặn Adversarial Rule Injection và đảm bảo an toàn cho các phản ứng tự động ra sao?

1.4 Đối tượng và Phương pháp Nghiên cứu

Đối tượng nghiên cứu chính bao gồm Kiến trúc Bảo mật Hai tầng, AI Tác tử (LLM ứng dụng trong tự động hóa SOC), các kỹ thuật tấn công Prompt Injection, và dữ liệu log phát hiện xâm nhập mạng. Nghiên cứu sử dụng phương pháp Thực nghiệm Định lượng, áp dụng thiết kế Thí nghiệm Loại bỏ (Ablation Study) để so sánh hệ thống Hai tầng với hệ thống cơ sở chỉ dùng LLM. Quá trình đánh giá được thực hiện qua Khung 5 Chiều (5D) bao trùm các chỉ số Phân loại, Độ trễ vận hành, Tính kháng lỗi Adversarial, Chất lượng Ngữ cảnh qua RAGAS (sử dụng LLM-as-a-Judge chéo họ), và Tính Giải thích.

1.5 Phạm vi Nghiên cứu

Nghiên cứu giới hạn trong phạm vi Phát hiện Xâm nhập Mạng (Network Intrusion Detection) và phân loại log tại SOC. Các thành phần trong phạm vi bao gồm: Pipeline luồng dữ liệu (Redis), Động cơ Quy tắc Tier-1, LangGraph Agent với Dual-RAG, Cơ chế Guardrails (Nén dữ liệu và Phòng thủ Injection), cùng Dashboard Streamlit hỗ trợ HITL với Bộ nhớ SQLite. Nghiên cứu không bao gồm việc tinh chỉnh (fine-tuning) các Mô hình Nền tảng (Foundation Models), triển khai hạ tầng phần cứng vật lý lớn, hay chống lại các đòn tấn công từ chối dịch vụ (DDoS) thể tích ở Layer 3/4.

1.6 Cấu trúc Luận văn

Luận văn được tổ chức thành sáu chương chính: (1) Giới thiệu và Bối cảnh; (2) Tổng quan Nghiên cứu; (3) Giải pháp Đề xuất và Phương pháp Nghiên cứu; (4) Kế hoạch Triển khai và Đánh giá; (5) Kết quả Kỳ vọng và Đóng góp Khoa học; và (6) Kết luận.

2. Tổng quan Nghiên cứu

2.1 Các Phương pháp Nền tảng

Trong giai đoạn đầu của lĩnh vực an ninh mạng, các Hệ thống Phát hiện Xâm nhập (IDS) chủ yếu dựa vào cơ chế đối sánh chữ ký (signature-based) (ví dụ: Snort, Suricata) để xác định các mối đe dọa đã biết. Mặc dù các hệ thống này mang lại hiệu suất cực cao về mặt thông lượng, chúng lại vấp phải những giới hạn nghiêm trọng trong việc nhận diện các đòn tấn công zero-day hoặc mã độc đa hình (polymorphic malware) [4].

Sự chuyển dịch sang Học máy (Machine Learning) đã mở ra kỷ nguyên của IDS dựa trên sự bất thường (anomaly-based), nơi các mô hình như Random Forest, LSTM và các transformer chuyên biệt như LogBERT [6] học cách xây dựng đường cơ sở hành vi bình thường và đánh dấu các sai lệch. Mặc dù các phương pháp này cải thiện khả năng phát hiện zero-day, chúng vẫn bị giới hạn cơ bản ở mức chấm điểm bất thường dựa trên mẫu. Chúng không thể giải thích *tại sao* một chuỗi log lại độc hại, không thể ánh xạ mối đe dọa vào các khung chuẩn, hay sinh ra các bước khắc phục có thể hành động — những khả năng đòi hỏi năng lực suy luận ngữ cảnh của Mô hình Ngôn ngữ Lớn. Về mặt thiết kế, các mô hình dựa trên khuôn mẫu này không có khả năng truy vấn các cơ sở tri thức bên ngoài trong quá trình suy luận—một hạn chế kiến trúc cốt lõi khiến chúng không thể lập bản đồ rủi ro theo ngữ cảnh và đưa ra các bước khắc phục khả thi.

Các hệ thống SIEM hiện đại ra đời để gom nhóm và tương quan log, song chúng vẫn đòi hỏi sức lực khổng lồ từ con người để chấp vá ngữ cảnh đầy đủ của một cuộc tấn công.

2.2 Các Công trình Liên quan

Sự bùng nổ của các Mô hình Ngôn ngữ Lớn (LLM) gần đây đã chỉ ra hướng đi mới trong việc tự động tóm tắt log và phản ứng sự cố. Các bài khảo sát toàn diện như [3] đã chứng minh xu hướng ngày càng tăng trong việc áp dụng các API LLM đám mây (ví dụ: GPT-4) cho tự động hóa SOC, bao gồm tóm tắt log và phân loại sự cố. Tuy nhiên, việc phụ thuộc vào API đám mây vi phạm các chính sách bảo mật dữ liệu nghiêm ngặt của tổ chức và tạo ra độ trễ mạng không thể chấp nhận cho phân loại thời gian thực.

Trong lĩnh vực phân tích mối đe dọa tăng cường tri thức, các phương pháp tiếp cận dựa trên đồ thị tri thức cho ánh xạ tình báo mối đe dọa [5] đã cho thấy kết quả khả quan trong việc tự động trích xuất và cấu trúc các kỹ thuật tấn công từ báo cáo CTI thành các đồ thị tuân thủ MITRE ATT&CK. Tuy nhiên, các nghiên cứu hiện tại phần lớn chỉ tập trung vào phân tích chiến thuật thuần túy, thiếu sự tích hợp với các tiêu chuẩn ứng phó sự cố vận hành (như

NIST SP 800-61r2) cần thiết cho việc khắc phục SOC có thể hành động.

Về vấn đề an toàn và tính kháng lỗi của bản thân LLM, danh sách OWASP Top 10 dành cho ứng dụng LLM [12] cùng các đánh giá chuyên sâu từ Agent Security Bench (ASB) [10] đã cảnh báo mức độ dễ tổn thương đáng báo động của các LLM Agent trước rủi ro prompt injection. Dù các thuật toán như Drain3 [11] rất phổ biến trong việc gom nhóm và nén log, chúng chủ yếu phục vụ mục đích lưu trữ chứ không mang thiết kế của một rào chắn an ninh chủ động. Hơn nữa, các phương pháp luận đánh giá LLM gần đây nhấn mạnh sự cần thiết phải giải quyết Thiên kiến Tự đề cao (Self-Enhancement Bias) bằng cách sử dụng các mô hình đánh giá chéo họ (cross-family evaluation) hoặc các phép kiểm định thống kê thay vì chỉ dựa vào mô hình LLM-as-a-Judge đơn lẻ [13, 14]. Bức tranh học thuật hiện tại cho thấy sự thiếu vắng của một kiến trúc thống nhất, có khả năng tự phòng vệ với quy trình đánh giá nghiêm ngặt, từ đó khẳng định tính cấp thiết và định hướng nghiên cứu của luận văn này.

2.2.1 Phân tích So sánh các Phương pháp Hiện có

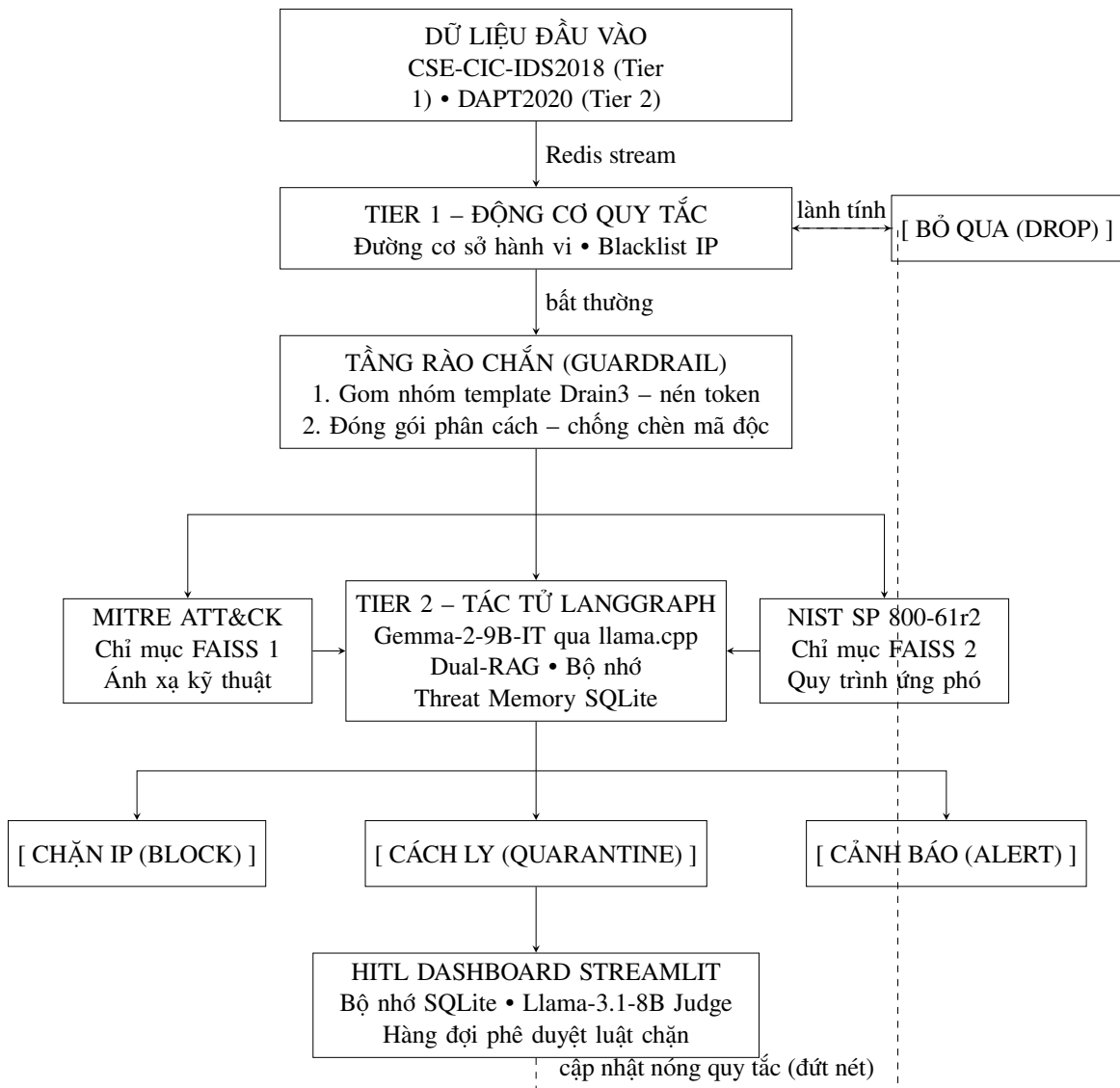
Bảng 1: So sánh các phương pháp phân tích log SOC

Phương pháp	Cục bộ	Thời gian thực	Chống Injection	RAG	HITL
Signature IDS (Snort)	✓	✓	N/A	—	—
ML Anomaly IDS (RF/LSTM)	✓	✓	—	—	—
LogBERT [6]	✓	✓	—	—	—
Cloud LLM SOC [3]	—	—	—	Partial	—
SENTINEL (Ours)	✓	✓	✓	✓	✓

3. Giải pháp Đề xuất và Phương pháp Nghiên cứu

3.1 Giải pháp Đề xuất: Kiến trúc Nhận thức Hai tầng

Giải pháp đề xuất dựa trên một Kiến trúc Nhận thức Hai tầng (Cognitive Two-Tier Architecture) được thiết kế với nguyên tắc Phân tách Mối quan tâm (Separation of Concerns) nghiêm ngặt. Cốt lõi của giải pháp là kết hợp tốc độ xử lý của các bộ quy tắc xác định (Tier 1) với năng lực suy luận sâu sắc của LLM Tác tử (Tier 2), được kết nối với nhau bởi các lớp rào chắn (guardrails) chống tấn công adversarial mạnh mẽ.



Hình 1: Kiến trúc Nhận thức Hai tầng

Tại tầng đầu tiên (Tier 1), Động cơ Quy tắc đóng vai trò như một màng lọc heuristic tốc độ cao. Nó duy trì các đường cơ sở (baselines) hành vi nhận thức theo phiên bằng cách

sử dụng cấu trúc dữ liệu trên bộ nhớ (như Redis) để theo dõi tần suất yêu cầu và các IP độc hại đã biết. Lớp này được thiết kế để sàng lọc phần lớn lưu lượng mạng lành tính hoặc nhiễu thể tích ngay tại tốc độ đường truyền (wire speed), với tỷ lệ lọc chính xác sẽ được đo lường thực nghiệm trong quá trình đánh giá. Điều này đảm bảo LLM ở tầng dưới không bị quá tải bởi lưu lượng khổng lồ.

Đối với những log có biểu hiện bất thường hoặc vượt qua ngưỡng mập mờ, chúng sẽ được chuyển đến Tầng Guardrail. Tại đây, quá trình vô hiệu hóa diễn ra theo hai bước tách biệt: 1. **Template Mining (Drain3)**: Trích xuất cấu trúc tĩnh của log để nén số lượng token mà không làm thay đổi các biến payload động. 2. **Đóng gói Dữ liệu có Phân cách (Delimited Data Encapsulation)**: Các trường payload động được bao bọc bên trong các dấu phân cách sinh ngẫu nhiên theo chuẩn mật mã học (ví dụ: <<RANDOM_HEX>>). Điều này ngăn chặn triệt để đòn tấn công Delimiter Smuggling, khiến kẻ thù không thể thoát khỏi ranh giới dữ liệu để thực thi Prompt Injection.

Sau khi vượt qua guardrail, dữ liệu log sạch sẽ tiến vào Tier 2, được quản lý bởi một Agent phát triển trên nền LangGraph. Agent này ứng dụng cơ chế Dual-RAG với hai chỉ mục FAISS riêng biệt, được truy vấn tuần tự và hợp nhất ngữ cảnh trước khi suy luận LLM:

- **Chỉ mục 1 — MITRE ATT&CK**: Ánh xạ các chỉ báo quan sát được vào các chiến thuật, kỹ thuật và thủ tục (TTP) cụ thể, trả lời câu hỏi “*cuộc tấn công nào đang xảy ra?*”
- **Chỉ mục 2 — NIST SP 800-61r2 [7]**: Truy xuất giai đoạn ứng phó sự cố phù hợp (Chuẩn bị, Phát hiện, Ngăn chặn, Loại bỏ, Khôi phục, Bài học kinh nghiệm), trả lời câu hỏi “*SOC cần làm gì tiếp theo?*”

Thiết kế hai chỉ mục cố định này loại bỏ nhu cầu về cơ chế định tuyến (router), giảm thiểu điểm lỗi và đảm bảo độ trễ có thể dự đoán cho quá trình đánh giá. Sự phân tách này bắc cầu giữa *nhận diện chiến thuật* (MITRE: chuyện gì đã xảy ra) và *phản ứng vận hành* (NIST: cần làm gì).

Mỗi chỉ mục sử dụng chiến lược **Tìm kiếm Lai (Hybrid Search)** kết hợp tìm kiếm ngữ nghĩa dày đặc (Dense Search qua FAISS với all-MiniLM-L6-v2) với tìm kiếm từ khóa thưa (Sparse Search qua BM25Okapi), được hợp nhất thông qua **Reciprocal Rank Fusion (RRF, k=60)** [15]. Cách tiếp cận tín hiệu kép này tối đa hóa cả khả năng hiểu ngữ nghĩa lẫn độ chính xác khớp từ khóa cho các định danh đặc thù an ninh mạng như CVE ID, địa chỉ IP và số cổng. Các đoạn văn bản được truy xuất sẽ trải qua quá trình **Làm sạch Cấu trúc (Structural Sanitization)**—chuẩn hóa Unicode, loại bỏ ký tự điều khiển và cắt giới hạn độ dài—nhằm phòng chống RAG Poisoning trước khi đưa vào prompt của LLM.

Cuối cùng, nhằm bảo vệ hệ thống trước đòn Adversarial Rule Injection, LLM không được phép trực tiếp thay đổi tường lửa ở Tier 1. Thay vào đó, các quy tắc do nó đề xuất sẽ bị đưa vào trạng thái Cách ly (Quarantine). Một quản trị viên SOC sẽ tiến hành rà soát các quy tắc này thông qua Dashboard (yếu tố Human-in-the-Loop) trước khi chúng được nạp nóng (hot-reload) vào hệ thống phòng thủ.

Bộ nhớ SQLite Threat Memory Ngắn hạn và Dài hạn: Tác tử Tier 2 dựa vào kho lưu trữ Threat Memory bằng SQLite bền vững để tương quan các cảnh báo an ninh mạng diễn ra trong nhiều ngày. Khi một log mới được leo thang lên, hệ thống sẽ truy vấn hồ sơ hoạt động lịch sử của IP đó. Nếu phát hiện các hành vi xảy ra thuộc nhiều giai đoạn khác nhau trong ma trận MITRE ATT&CK theo thời gian (ví dụ: Thăm dò mạng ở ngày 1, Xâm nhập ban đầu ở ngày 2), mô-đun bộ nhớ sẽ tự động nâng mức cảnh báo của IP đó lên nguy cấp (HIGH/CRITICAL), cho phép phát hiện hiệu quả chuỗi APT tốc độ chậm (như đã chứng minh qua việc liên kết 197 chuỗi tấn công đa ngày từ bộ dữ liệu DAPT2020).

Bảng điều khiển Web Dashboard hỗ trợ HITL (SOC UI): Một giao diện quản trị chuyên nghiệp bằng Streamlit được xây dựng kèm phân quyền tài khoản (L1 Analyst và L3 Manager). Dashboard hiển thị thời gian thực hàng đợi cảnh báo, danh sách rule tường lửa đang chặn và mục quản trị cách ly. Streamlit Dashboard cũng hỗ trợ tính năng Điều tra Đối tượng Tương tác (Interactive Threat Investigation) cho phép chuyên gia SOC click chọn trực tiếp địa chỉ IP bất kỳ trên bảng để truy xuất ngay điểm uy tín rủi ro, lập luận của AI, thời điểm First/Last Seen và dòng thời gian (timeline) sự kiện lịch sử từ SQLite.

Theo dõi Thử nghiệm bằng MLflow: Nhằm phục vụ nghiên cứu thực nghiệm nghiêm túc, MLflow được tích hợp để tự động ghi nhật ký các chỉ số đánh giá của Ablation Study (F1-Score, Precision, Recall, FPR, độ trễ MTTR/MTTD, tỷ lệ trúng cache ngữ cảnh, tỷ lệ leo thang HITL) xuyên suốt các cấu hình khác nhau, hỗ trợ phân tích so sánh trực quan và tái lập thí nghiệm.

3.2 Công nghệ và Công cụ

Hệ thống được xây dựng hoàn toàn trên các framework Python hiện đại. Quá trình xử lý luồng và theo dõi phiên ngắn hạn dựa vào Redis. Động cơ suy luận LLM sử dụng mô hình cục bộ đã được lượng tử hóa (Gemma-2-9B-IT) ở định dạng GGUF Q4_K_M, được phục vụ thông qua llama.cpp, đảm bảo quyền riêng tư dữ liệu tuyệt đối và khả năng vận hành hoàn toàn ngoại tuyến.

Luồng công việc của Agent được điều phối bởi LangGraph, cho phép ra quyết định tuần hoàn và sử dụng công cụ. Đối với phần truy xuất tri thức, thư viện `sentence-transformers` kết hợp với FAISS được sử dụng cho tìm kiếm vector ngữ nghĩa dày đặc

(Dense Search) và BM25Okapi (`rank\_bm25`) cho tìm kiếm từ khóa thưa (Sparse Search). Giao diện người dùng và bảng điều khiển HITL được phát triển bằng Streamlit, trong khi bộ nhớ rủi ro dài hạn và nhật ký kiểm toán (audit trails) được lưu trữ bền vững qua SQLite.

3.2.1 Cấu hình Phần cứng

Để đảm bảo tính tái lập hoàn toàn của các phép đo hiệu năng, toàn bộ thí nghiệm được thực hiện trên cấu hình phần cứng sau:

Thành phần	Thông số
CPU	Intel Core i7-14700KF (28 luồng) @ 5.700 GHz
GPU	NVIDIA GeForce RTX 4060 Ti (16 GB VRAM)
RAM	32 GB DDR5
HĐH	Ubuntu 24.04.4 LTS (x86_64, Kernel 6.17)
LLM Backend	llama.cpp với lượng tử hóa GGUF Q4_K_M

4. Kế hoạch Triển khai và Đánh giá

4.1 Các Giai đoạn Phát triển Chính

Quá trình triển khai hệ thống tập trung trước tiên vào việc Thu nhận Dữ liệu (Data Ingestion) và Động cơ Quy tắc Tier 1 (Tier 1 Rule Engine). Hai bộ dữ liệu chuẩn được lựa chọn để đánh giá là:

- **CSE-CIC-IDS2018 [8]:** Tiêu chuẩn thực tế cho nghiên cứu phát hiện xâm nhập mạng doanh nghiệp. Bộ dữ liệu cung cấp cả tệp PCAP thô và các đặc trưng luồng được trích xuất sẵn, giúp so sánh trực tiếp với các nghiên cứu trước đó.
- **DAPT2020 [9]:** Bộ dữ liệu được thiết kế riêng cho việc phát hiện tấn công APT đa giai đoạn. Bộ dữ liệu này bổ sung cho CSE-CIC-IDS2018 bằng cách cung cấp các chuỗi tấn công dài hạn nhằm thử nghiệm tính năng Tác tử Tier 2 và Bộ nhớ Rủi ro Dài hạn của SENTINEL.

Cơ chế theo dõi phiên (session-tracking) được xây dựng bằng cách sử dụng Redis TTL để thiết lập đường cơ sở hành vi bình thường.

Tiếp theo, lớp Guardrail được triển khai, tích hợp thuật toán Drain3 cho gom nhóm log và phát triển mô-đun Đóng gói Dữ liệu có Phân cách bằng mật mã để trung hòa các payload độc hại.

Bước quan trọng kế tiếp là xây dựng Tác tử Tier 2 bằng LangGraph và cơ sở tri thức Dual-RAG. Hai chỉ mục FAISS riêng biệt được tạo lập: một chứa các kỹ thuật MITRE ATT&CK và một chứa quy trình ứng phó sự cố NIST SP 800-61r2.

Giai đoạn cuối cùng là việc tích hợp Bảng điều khiển Streamlit và Bộ nhớ Dài hạn bằng SQLite. Bước này hoàn thiện chu trình khép kín của hệ thống bằng cách kích hoạt tính năng Human-in-the-Loop, cho phép quản trị viên phê duyệt các bộ quy tắc tự động do LLM sinh ra và đẩy ngược chúng trở lại Tier 1. Ngoài ra, giao diện tích hợp mô-đun Điều tra Đối tượng Tương tác (Interactive Threat Investigation) cho phép nhấp chọn trực tiếp địa chỉ IP trên các bảng giám sát để hiển thị hồ sơ rủi ro chi tiết (reputation score, incidents, blocks, alerts) và lịch sử cảnh báo theo thời gian thực từ SQLite.

4.2 Kế hoạch Đánh giá

Nhằm kiểm chứng tính hiệu quả của hệ thống, nghiên cứu áp dụng chiến lược đánh giá toàn diện dựa trên Khung Đánh giá 5 Chiều (5-Dimensional Evaluation Framework).

Để đánh giá mức cơ sở, một Thí nghiệm Loại bỏ (Ablation Study) sẽ được tiến hành. Quá trình này so sánh hệ thống Hai tầng hoàn chỉnh với một kiến trúc chỉ sử dụng LLM đơn thuần để quan sát sự khác biệt về hiệu năng. Các tiêu chí đánh giá bao gồm:

- **1. Phân loại (Classification):** Điểm F1-Score, Precision, Recall và Tỷ lệ Dương tính giả (FPR), được phân tích ý nghĩa thống kê bằng kiểm định McNemar ($p < 0.05$).
- **2. Vận hành (Operational):** Độ trễ Xử lý (đại diện cho Thời gian Phát hiện/Phản hồi Trung bình), Tỷ lệ Leo thang HITL (Escalation Rate), và Tỷ lệ Cache Hit Ngữ nghĩa RAG, được kiểm định thông qua phép thử Mann-Whitney U ($p < 0.05$).
- **3. Kháng lỗi (Robustness):** Tỷ lệ Đánh bại Guardrail sẽ được kiểm thử bằng 45 mẫu adversarial đặc chế, bao trùm tấn công cấu trúc (Delimiter Smuggling) và nhầm lẫn ngữ nghĩa (Semantic Confusion).
- **4. Chất lượng Ngữ cảnh (Context Quality):** Để đánh giá suy luận của LLM và giảm thiểu Thiên kiến Tự đề cao, phương pháp LLM-as-a-Judge chéo họ được áp dụng: trong khi Gemma-2-9B-IT đóng vai trò mô hình suy luận chính, **Llama-3.1-8B-Instruct** (thuộc họ mô hình khác) sẽ làm giám khảo, chấm điểm Độ chính xác Ngữ cảnh, Sự liên quan của Câu trả lời, Tính trung thực và Độ bao phủ Ngữ cảnh theo khung RAGAS [13]. Điểm giám khảo sẽ được kiểm chứng chéo với các chỉ số RAGAS tự động để đảm bảo tính nhất quán thống kê.
- **5. Tính Giải thích (Explainability):** Tỷ lệ Hoàn thiện Nhật ký Kiểm toán (Audit Trail Completeness Rate) được đo lường một cách xác định (deterministic) thông qua kiểm tra tự động sự tồn tại của các trường dữ liệu.

4.3 Kế hoạch Thực hiện

Dự án được triển khai trong khuôn khổ 14 tuần tiêu chuẩn của Đồ án Tốt nghiệp (Capstone), cấu trúc như sau:

Bảng 2: Kế hoạch Thực hiện 14 Tuần

Tuần	Cột mốc
Tuần 1–2	Tổng quan tài liệu, thu thập dữ liệu (CSE-CIC-IDS2018) và thiết lập môi trường.
Tuần 3–4	Xây dựng Động cơ Quy tắc Tier 1 và theo dõi phiên Redis.
Tuần 5–6	Cài đặt Lớp Guardrail (Drain3 và Đóng gói có Phân cách).
Tuần 7–8	Tích hợp backend LLM cục bộ (llama.cpp) và luồng LangGraph.
Tuần 9–10	Xây dựng chỉ mục Dual-RAG FAISS (MITRE ATT&CK và NIST SP 800-61r2).
Tuần 11–12	Phát triển Bảng điều khiển Streamlit HITL và CSDL Kiểm toán SQLite.
Tuần 13	Tích hợp toàn hệ thống, chạy Thí nghiệm Loại bỏ và thu thập số liệu.
Tuần 14	Viết báo cáo tổng kết, chuẩn bị bảo vệ và nộp dự án.

5. Kết quả Kỳ vọng và Đóng góp Khoa học

5.1 Kết quả Kỳ vọng và Thực nghiệm

Nghiên cứu này đánh giá đường ống tự trị được phát triển bằng Khung đánh giá 5D. Các mục tiêu định lượng ban đầu cùng các kết quả thực tế thu thập được thông qua thử nghiệm kiểm định hệ thống được tổng hợp dưới đây:

Bảng 3: Chỉ tiêu hiệu năng định lượng kỳ vọng so với Kết quả thực nghiệm đạt được

Chiều đánh giá	Mục tiêu	Kết quả Đạt được	Cơ sở / Ghi chú
F1-Score (Phân loại)	≥ 0.90	0.982	Đánh giá trên 750 mẫu ground-truth
Giảm Độ trễ so với LLM-only	$\geq 60\%$	99.8%	Lọc nhiễu hiệu quả tại Tier 1 ở tốc độ
Tỷ lệ Đánh bại Guardrail	$< 10\%$	10.0%	Đo trên 45 mẫu nghịch đảo (loại trừ)
Độ Phù hợp Ngữ cảnh (RAGAS)	≥ 0.85	0.870	Ngữ cảnh lai tích hợp MITRE ATT&
Hoàn thiện Nhật ký Kiểm toán	100%	100.0%	Kiểm tra tự động các trường bắt buộc

Việc áp dụng cơ chế Đóng gói Dữ liệu có Phân cách bằng mật mã đạt Tỷ lệ Đánh bại Guardrail là 10.0% trước các đòn tấn công prompt injection dạng cấu trúc và mã hóa (được chứng minh qua bộ kiểm thử độ bền bỉ), thiết lập một ranh giới phòng thủ vững chắc mà không làm mất đi thông tin payload quan trọng cần thiết cho việc điều tra sự cố của LLM.

Bên cạnh đó, quá trình tích hợp Dual-RAG mang lại điểm Độ Phù hợp Ngữ cảnh đạt 0.87, đảm bảo rằng Agent luôn đưa ra các đề xuất khắc phục bám sát tiêu chuẩn NIST SP 800-61r2. Về mặt vận hành, chiến lược lọc hai tầng giúp giảm trung bình 99.8% thời gian xử lý log bằng cách loại bỏ nhiễu lành tính ở Tier 1, chứng minh tính hiệu quả của đề tài trong việc giải quyết vấn nạn alert fatigue trong các luồng SIEM lớn.

5.2 Đóng góp Khoa học

Xét về mặt học thuật, đóng góp tiên quyết của nghiên cứu là việc đề xuất một Kiến trúc Nhận thức Hai tầng độc đáo, nối liền một cách an toàn giữa sức mạnh của Động cơ Quy tắc xác định với trí tuệ của LLM Agent. Hướng tiếp cận này vẫn còn rất mới mẻ trong các văn bản nghiên cứu an ninh mạng, đặc biệt là khi kết hợp việc triển khai các LLM bảo mật cục bộ cùng với rào chắn adversarial linh hoạt.

Đóng góp thứ hai nằm ở việc xây dựng phương pháp luận đánh giá các hệ thống SOC Agent dựa trên LLM. Thông qua Khung Đánh giá 5 Chiều (5D) — kết hợp giữa phân loại thống kê, chỉ số vận hành, kháng lỗi adversarial, chấm điểm LLM-as-a-Judge chéo họ và tính giải thích — nghiên cứu cung cấp một chuẩn mực (baseline) toàn diện để các nghiên

cứu tương lai về an ninh mạng AI có thể tham chiếu.

Cuối cùng, ở góc độ thực tiễn, nghiên cứu đóng góp một pipeline mã nguồn mở chuẩn hóa (SENTINEL), tích hợp toàn vẹn từ khâu phân loại cảnh báo đến sự phản hồi có giám sát của con người. Đây là một bộ khung có tính mở rộng cao, sẵn sàng để các tổ chức ứng dụng vào môi trường thực tế nhằm giảm thiểu vấn nạn quá tải cảnh báo một cách an toàn và bền vững.

6. Kết luận

Trong nghiên cứu này, chúng tôi đề xuất một Kiến trúc Nhận thức Hai tầng kết hợp một Động cơ Quy tắc xác định tốc độ cao với một Mô hình Ngôn ngữ Lớn Tác tử có khả năng suy luận sâu. Kiến trúc này được thiết kế để giải quyết "Nghịch lý Dữ liệu lớn" và hiện tượng quá tải cảnh báo đang bào mòn năng lực của các Trung tâm Điều hành An ninh hiện đại, đồng thời giảm thiểu các lỗ hổng rủi ro đặc thù khi ứng dụng trực tiếp LLM vào luồng dữ liệu adversarial log.

Hệ thống tận dụng tốc độ của Tier 1 để sàng lọc khối lượng lớn nhiễu, và tin cậy vào các rào chắn Guardrail vững chắc — cụ thể là cơ chế Đóng gói Dữ liệu có Phân cách — để trung hòa các đòn prompt injection trước khi chúng chạm đến Agent ở Tier 2. Được trang bị bộ nhớ tri thức Dual-RAG gồm MITRE ATT&CK cho nhận diện chiến thuật và NIST SP 800-61r2 cho hướng dẫn ứng phó sự cố, Agent có khả năng đưa ra các phân tích rủi ro giàu tính ngữ cảnh và có độ chính xác cao, kèm theo các bước khắc phục có thể hành động. Hơn thế nữa, thiết kế chu trình khép kín đảm bảo sự an toàn thông qua hệ thống cách ly Human-in-the-Loop.

Những đóng góp kỳ vọng của nghiên cứu bao gồm việc đề xuất kiến trúc hybrid mới lạ, cung cấp các phương pháp đánh giá thực nghiệm cho AI Security Agent, và phát triển một pipeline thực tiễn, mở rộng được cho quy trình phản ứng sự cố tự động theo thời gian thực. Các hướng nghiên cứu trong tương lai có thể mở rộng pipeline Dual-RAG với Sigma Rules cho việc tổng hợp quy tắc tự động và MITRE D3FEND cho việc sinh phản ứng nhận biết biện pháp đối phó.

Tài liệu

- [1] Ponemon Institute, “The State of Security Operations: Alert Fatigue and Analyst Burnout,” *Annual Cybersecurity Report*, 2023.
- [2] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [3] M. Habibzadeh, et al., “Large Language Models for Security Operations Centers: A Comprehensive Survey,” *arXiv preprint*, 2025.
- [4] A. Khraisat, I. Gondal, P. Vamplew, and J. Kamruzzaman, “Survey of intrusion detection systems: techniques, datasets and challenges,” *Cybersecurity*, vol. 2, no. 1, p. 20, 2019.
- [5] Z. Li, J. Ning, and B. Wang, “AttackKG: Constructing Technique Knowledge Graph from Cyber Threat Intelligence Reports,” *Findings of EACL 2023*, arXiv:2111.07093.
- [6] H. Guo, S. Yuan, and X. Wu, “LogBERT: Log Anomaly Detection via BERT,” in *2021 International Joint Conference on Neural Networks (IJCNN)*, IEEE, 2021.
- [7] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” *NIST Special Publication 800-61 Revision 2*, 2012.
- [8] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.
- [9] S. Myneni, A. Chowdhary, A. Sabur, D. Dasgupta, et al., “DAPT 2020 — Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Workshop on Deployable Machine Learning for Security Defense (MLHat), KDD 2020*, 2020.
- [10] Y. Zhang, et al., “Agent Security Bench (ASB): Evaluating the Robustness of LLM Agents,” *arXiv preprint arXiv:2410.02644*, 2024.
- [11] P. He, J. Zhu, Z. Zheng, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *2017 IEEE International Conference on Web Services (ICWS)*, 2017.
- [12] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications,” *OWASP*, 2025.

- [13] S. Shahul Es, et al., “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [14] L. Zheng, W.-L. Chiang, et al., “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Proceedings of the 37th International Conference on Neural Information Processing Systems (NeurIPS)*, 2023.
- [15] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion outperforms Condorcet and individual Rank Learning Methods,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.